

PROJECT 5 OF 8 — PART 1: INCIDENT DEEP DIVE
SOLARWINDS SUPPLY CHAIN ATTACK (2020)*Nation-State Attack · Supply Chain · 18,000 Victims · 9 Months Undetected*

 **THIS PROJECT:** Understand what happened, map the attack, research the CVE. This project ends with a CVE Research Worksheet (50 points).

 **CVE / ADVISORY:** CVE-2020-10148 (SolarWinds Orion API Authentication Bypass, CVSS 9.8 CRITICAL) — nvd.nist.gov

INCIDENT OVERVIEW

In late 2020, security firm FireEye discovered that nation-state attackers — later attributed to Russia's SVR intelligence service (APT29/Cozy Bear) — had injected malicious code (SUNBURST) into SolarWinds' Orion IT monitoring software update. Approximately 18,000 organizations installed the trojanized update. Victims included U.S. Departments of Treasury, State, Homeland Security, Defense, and Justice, plus Microsoft and thousands of private organizations. Attackers remained undetected for 9+ months, moving silently through government networks. This is widely considered the most sophisticated cyberattack in history.

KEY FACTS AT A GLANCE

- ~18,000 organizations downloaded the trojanized Orion software update
- ~100 organizations were actively exploited for deeper access (including U.S. government agencies)
- Attacker: APT29 / Cozy Bear — Russia's SVR foreign intelligence service
- SUNBURST backdoor stayed dormant for 12–14 days after installation before activating
- Used DNS-based C2 — traffic blended perfectly with legitimate Orion network monitoring
- Attackers remained undetected for approximately 9 months
- Microsoft President Brad Smith called it "the most sophisticated and largest cyberattack in history"

PROJECT 5 · DAY 1**MONDAY — INCIDENT INTRODUCTION + CIA TRIAD****1–2 HRS**

 **OBJECTIVE:** Students understand the SolarWinds Supply Chain Attack at a high level and apply the CIA Triad to identify which pillars were violated and how.

PROJECT 5 • DAY 2

TUESDAY — CYBER KILL CHAIN — ALL 7 PHASES

1-2 HRS

 **OBJECTIVE:** Students map the complete attack through all 7 Kill Chain phases using specific incident evidence.

PROJECT 5 • DAY 3

WEDNESDAY — MITRE ATT&CK — HANDS-ON LAB

1-2 HRS

 **OBJECTIVE:** Students identify specific ATT&CK techniques, navigate attack.mitre.org, and explain each technique in plain English.

PROJECT 5 • DAY 4

THURSDAY — CVE RESEARCH LAB + WORKSHEET
SUBMISSION (50 PTS)

1-2 HRS

 **OBJECTIVE:** Students research the CVE or CISA advisory, build the incident timeline, finalize and submit the CVE Research Worksheet.

 **DUE:** Thursday of this project. Submit to your instructor.

[10 pts] What is the CVE number and CVSS score for this incident? If no CVE exists, what CISA advisory or identifier applies? What does the CVSS score (or the absence of a CVE) tell you about the nature of this vulnerability?

[10 pts] Describe the vulnerability or weakness in your own words — plain English, no jargon. A non-technical reader should completely understand what went wrong.

[10 pts] When was the official patch or fix released? How much time passed between the fix being available and the breach occurring? What does that timeline tell you about the organization's security practices?

[10 pts] Who was involved in containing this incident? What specific actions were taken? How long did full containment take?

[10 pts] List your 3 most critical "From Here On Out" recommendations for any organization that uses similar technology. For each, explain specifically WHY it would have prevented or reduced this breach.

REFERENCES & RESOURCES

- FireEye Blog: "Highly Evasive Attacker Leverages SolarWinds Supply Chain" (December 13, 2020) — [mandiant.com](https://www.mandiant.com)
- CISA Emergency Directive 21-01 — [cisa.gov/emergency-directive-21-01](https://www.cisa.gov/emergency-directive-21-01)
- nvd.nist.gov/vuln/detail/CVE-2020-10148 — full technical details
- U.S. Senate Intelligence Committee: SolarWinds Hearing (February 23, 2021)
- Executive Order 14028 on Improving the Nation's Cybersecurity — [whitehouse.gov](https://www.whitehouse.gov)
- MITRE ATT&CK: attack.mitre.org — search T1195, T1071, T1027

